

Manual 40 — Implementación Controlada de la Política de Seguridad CJIS

****Línea base controlada:**** FBI CJIS Security Policy Version 6.1, 25 de junio de 2026, sujeta a reverificación al momento del release.

****Límite:**** requisitos de la política FBI, requisitos de implementación de la CSA estatal, adendas/acuerdos de seguridad, contratos, materiales complementarios y prácticas de la organización permanecen como capas de fuente distintas.

****Regla de release:**** reverificar la política CJIS vigente del FBI y los requisitos CSA aplicables al congelar el candidato.

Chapter 01 — Propósito, alcance y jerarquía de fuentes

Establezca jerarquía controlada de fuentes CJIS, método de aplicabilidad, responsables, control de cambios e índice de evidencia. No trate ejemplos, material del resource center ni prácticas locales como texto vinculante independiente de la política FBI.

Chapter 02 — Aplicabilidad y límites de CJI

Determine si sistemas, usuarios, ubicaciones, interfaces y proveedores acceden, procesan, transmiten, almacenan o soportan Criminal Justice Information. Documente inclusiones, exclusiones y decisiones ambiguas con fundamento enlazado a fuentes.

Chapter 03 — Modelo de agencia, CSA y responsabilidades

Defina responsabilidades de agencia, CSA, contratación, hosting, soporte y proveedores para el modelo operativo concreto. Mantenga matrices de responsabilidad, acuerdos, rutas de escalamiento y evidencia de autoridad.

Chapter 04 — Gobernanza y accountability

Asigne funciones ejecutivas, security, privacy, legal, operaciones, arquitectura, procurement, RR. HH. y service owners. Mantenga aprobaciones, excepciones, decisiones de riesgo, evidencia de management review y ownership de acciones correctivas.

Chapter 05 — Inventario de sistemas y datos

Inventarie aplicaciones, infraestructura, endpoints, interfaces, servicios cloud, administradores, data stores, backups y terceros relacionados con CJI. Mantenga owners, data flows, límites de sistema, dependencias e historial de cambios.

Chapter 06 — Mapeo de la política de seguridad

Mapee requisitos CJIS aplicables a controles, procedimientos, configuraciones técnicas, objetos de evidencia y métodos de prueba. Preserve trazabilidad hacia la versión exacta de la política controlada.

Chapter 07 — Screening y suitability de personal

Defina screening, autorización, onboarding, cambios de estado, suspensión y offboarding para personal con acceso o funciones de soporte relevantes. Mantenga evidencia de terminación, decisiones, excepciones y revisión periódica.

Chapter 08 — Concientización y capacitación por rol

Imparta capacitación CJIS basada en roles y alineada con responsabilidades de acceso, administración, operación e incidentes. Mantenga currículum, completitud, competency checks, remediación y triggers de refresco.

Chapter 09 — Protección física

Defina controles de acceso físico, visitantes, instalaciones, workspace, dispositivos, media y ambiente para entornos CJI aplicables. Mantenga registros de acceso, revisiones de instalaciones, excepciones y acciones correctivas.

Chapter 10 — Ciclo de vida de identidades y cuentas

Controle solicitud, aprobación, provisioning, modificación, revisión periódica, suspensión y terminación de cuentas. Mantenga evidencia de identidad, ownership de cuenta, banderas privilegiadas, resultados de review y tiempos de revocación.

Chapter 11 — Autenticación avanzada y MFA

Aplique controles de autenticación apropiados al escenario de usuario, dispositivo, red, acceso remoto y privilegios conforme a la línea base CJIS vigente y requisitos CSA aplicables. Registre diseño técnico, excepciones, pruebas y controles compensatorios cuando estén permitidos.

Chapter 12 — Acceso privilegiado

Restrinja accesos privilegiados a personal autorizado y rutas administrativas aprobadas. Mantenga inventarios de roles privilegiados, justificaciones, session controls, monitoring, evidencia de review y procedimientos break-glass.

Chapter 13 — Menor privilegio y control de acceso

Implemente autorización adecuada al rol, segregación de funciones, need-to-know, recertificación periódica y gobernanza de cambios de acceso. Mantenga matrices, aprobaciones, excepciones y evidencia de prueba.

Chapter 14 — Cifrado en tránsito

Proteja CJI en tránsito a través de conexiones internas, externas, remotas, wireless, cloud y de terceros mediante mecanismos criptográficos aprobados. Mantenga baselines de protocolo, evidencia de certificados/keys, configuration checks y excepciones.

Chapter 15 — Cifrado en reposo

Proteja CJI almacenada cuando lo exija el contexto aplicable CJIS/CSA. Mantenga inventarios de storage, decisiones de cifrado, settings técnicos, dependencias de claves, excepciones y evidencia de validación.

Chapter 16 — Gobernanza criptográfica y de claves

Defina ownership, generación, almacenamiento, rotación, revocación, recuperación, backup y retiro de claves/certificados que protegen CJI. Mantenga inventarios, custodios, registros de cambio y resultados de pruebas.

Chapter 17 — Logging y registros de auditoría

Capture eventos relevantes para seguridad en sistemas CJI, actividad administrativa, autenticación, acceso, cambios de configuración e investigación de incidentes según aplique. Mantenga alcance, racional de retención, access controls, evidencia de review y excepciones.

Chapter 18 — Monitoring y sincronización de tiempo

Mantenga monitoring, alerting, time synchronization, event correlation y escalamiento suficientes para operaciones de seguridad e integridad de evidencia. Conserve cobertura, fuentes de tiempo, handling de alertas y evidencia de revisión.

Chapter 19 — Protección de media

Controle creación, marcado, almacenamiento, transporte, reutilización, sanitización y disposición de media con CJI. Mantenga chain of custody, evidencia de sanitización, destrucción, excepciones y verificaciones periódicas.

Chapter 20 — Acceso móvil, remoto y wireless

Gobierne dispositivos móviles, acceso remoto, teletrabajo, conectividad wireless y sistemas portátiles según aplicabilidad y riesgo documentados. Mantenga configuraciones aprobadas, autorización de usuarios, device controls, métodos de conexión, monitoring y excepciones.

Chapter 21 — Arquitectura de red y seguridad

Documente segmentación, trust boundaries, security zones, conexiones externas, management networks, rutas administrativas y tecnologías protectoras. Mantenga diagramas, configuration baselines, aprobaciones y revisiones.

Chapter 22 — Vulnerabilidades, patching y configuración

Defina identificación, priorización y remediación de vulnerabilidades, patching, secure configuration, change control y excepciones para sistemas CJI y dependencias. Mantenga scans/tests, tracking de remediación, baselines aprobados y decisiones de riesgo.

Chapter 23 — Respuesta y reporte de incidentes

Integre eventos CJI en intake, triage, containment, preservación de evidencia, escalamiento, reporting, recuperación y lessons learned. Mantenga incident records, decisiones de notificación, timelines, comunicaciones y acciones correctivas.

Chapter 24 — Gobernanza de cloud y service providers

Evalúe cloud, managed, hosted, SaaS, soporte e infraestructura para aplicabilidad CJI, responsabilidades, acceso, ubicación de datos, seguridad, monitoring, subcontracting, incidentes, retención y salida. Mantenga due diligence, contratos, arquitectura, aprobaciones y oversight.

Chapter 25 — Outsourcing, security addenda y acuerdos

Mantenga acuerdos requeridos, security addenda, controles contractuales, declaraciones de responsabilidad y evidencia de cumplimiento para terceros. Distinga política FBI, implementación CSA, deberes contractuales y controles internos.

Chapter 26 — Backup, resiliencia y continuidad

Proteja backups y capacidades de recuperación de sistemas CJI de acuerdo con requisitos de seguridad, disponibilidad, integridad y acceso. Mantenga inventarios, restoration tests, recovery objectives, decisiones de procesamiento alternativo y acciones correctivas.

Chapter 27 — Retención y disposición de datos

Defina retención, archivo, eliminación, sanitización, legal hold y disposal usando requisitos CJIS, records, legales, contractuales y de agencia aplicables. No presente CJIS como un calendario universal de retención.

Chapter 28 — Auditorías y assessments

Planifique y ejecute reviews internos, technical testing, validación de evidencia, assessments externos/CSA y tracking de remediación. Mantenga alcance, muestras, findings, severidad, ownership, fechas, retests y decisiones de cierre.

Chapter 29 — Acciones correctivas y excepciones

Gobierne findings, corrective actions, desviaciones temporales, compensating measures, risk acceptance, expiración y reapproval. Mantenga root cause, owner, target date, evidencia, approvals y validación de cierre.

Chapter 30 — Métricas y management review

Monitoree excepciones de access review, patches vencidos, findings de privilegios, training completion, incidentes, findings abiertos, problemas de proveedores y change-watch. Management review debe documentar decisiones, recursos, escalamiento y prioridades.

Chapter 31 — Localización, proveniencia y evidencia de release

Congele candidatos EN/es-419/pt-BR antes de la revisión final exacta. Vincule identidades DOCX/PDF a SHA-256 y preserve estructura, paridad, accesibilidad, rendered-page review, versión de fuentes, workflow security y staging.

Chapter 32 — Roadmap y reverificación al release

Implemente por fases: aplicabilidad/inventario; gobernanza; personas/acceso; arquitectura/criptografía; logging/monitoring; endpoint/media/remoto; proveedores; incidentes/resiliencia; assurance; mejora continua. Antes de publicar, reverifique la versión vigente de FBI CJIS Security Policy y requisitos CSA aplicables; la publicación permanece secuencial después del Manual 39.